ĐẠI HỌC THÁI NGUYÊN
TRƯỜNG ĐẠI HỌC CÔNG NGHỆ THÔNG TIN VÀ TRUYỀN THÔNG

BÁO CÁO ĐỒ ÁN MÔN HỌC
TRIỂN KHAI VÀ QUẢN TRỊ HỆ THỐNG PHẦN MỀM

ĐỀ TÀI SỐ 13:
WEBSITE PORTFOLIO / GIỚI THIỆU CÁ NHÂN

Kiến trúc Container: PHP 8.2 FPM, Nginx, MySQL, Prometheus, Grafana, Loki & Promtail

Giảng viên hướng dẫn: **Hoàng Văn Tâm**

Sinh viên thực hiện: **Vũ Bá Hùng**

Mã số sinh viên (MSSV): **DTC245180186**

Lớp chuyên ngành: **KTPM K23C**

Học kỳ / Năm học: **Năm học 2025 - 2026**

Thái Nguyên, Năm 2026

LỜI CAM ĐOAN & NGUYÊN TẮC THỰC HIỆN

Tôi xin cam đoan đây là công trình nghiên cứu và triển khai thực tế của bản thân tôi dưới sự hướng dẫn của Giảng viên môn học Triển khai và Quản trị Hệ thống Phần mềm. Toàn bộ mã nguồn, cấu hình Docker Compose, hạ tầng giám sát Prometheus/Grafana, hệ thống thu thập log Loki/Promtail, cũng như các cơ chế tăng cường bảo mật (Hardening) đều được thiết lập, chạy thử và kiểm chứng trực tiếp trên hệ thống đang hoạt động.

Báo cáo này phân định rõ ràng 3 trạng thái độc lập cho từng hạng mục công việc:

- **1. Đã viết mã / cấu hình:**File mã nguồn, cấu hình đã được viết hoàn chỉnh trong repository.
- **2. Đã chạy thử:**Dịch vụ đã được build, khởi động và thực thi lệnh mà không gặp lỗi cú pháp hay crash.
- **3. Đã kiểm chứng đạt:**Đã có dữ liệu thật từ request HTTP, câu lệnh query DB, metrics thực tế từ Exporter, dòng log trích xuất từ Loki và ảnh screenshot minh chứng.

CHƯƠNG 1: TỔNG QUAN HẠ TẦNG VÀ DỊCH VỤ DOCKER COMPOSE

Hệ thống Đề 13 được triển khai hoàn chỉnh bằng Docker Compose v2 gồm 11 container micro-services, phân tách làm 3 mạng cô lập:

1.1 Trạng Thái Vận Hành Thực Tế (Kết Quả Lệnh docker compose ps)

Dưới đây là kết quả kiểm tra thực tế trạng thái các container sau khi khởi chạy hệ thống:

Container Name	Image & Tag	Ports / Binding	Trạng Thái Thực Tế	Đánh Giá Kiểm Chứng
portfolio_nginx	nginx:1.25.4-alpine	80:80, 443:443	Up (healthy)	Đã kiểm chứng đạt
portfolio_php	13-php (PHP 8.2 Alpine)	Nội bộ: 9000/tcp	Up (healthy)	Đã kiểm chứng đạt
portfolio_mysql	mysql:8.0.36	Nội bộ: 3306/tcp	Up (healthy)	Đã kiểm chứng đạt
portfolio_phpmyadmin	phpmyadmin:5.2.1-apache	127.0.0.1:8080:80	Up	Đã kiểm chứng đạt
portfolio_prometheus	prom/prometheus:v2.50.1	127.0.0.1:9090:9090	Up (healthy)	Đã kiểm chứng đạt
portfolio_grafana	grafana/grafana:10.3.3	127.0.0.1:3000:3000	Up (healthy)	Đã kiểm chứng đạt
portfolio_loki	grafana/loki:2.9.4	127.0.0.1:3100:3100	Up (healthy)	Đã kiểm chứng đạt
portfolio_promtail	grafana/promtail:2.9.4	Nội bộ	Up	Đã kiểm chứng đạt
portfolio_cadvisor	cadvisor:v0.47.2	Nội bộ: 8080/tcp	Up (healthy)	Đã kiểm chứng đạt (*)
portfolio_nginx_exporter	nginx-prometheus-exporter:1.1.0	Nội bộ: 9113/tcp	Up	Đã kiểm chứng đạt
portfolio_mysql_exporter	mysqld-exporter:v0.15.1	Nội bộ: 9104/tcp	Up	Đã kiểm chứng đạt

(*) Ghi chú kỹ thuật về môi trường: Trên môi trường Docker Desktop for Windows (WSL2 backend), cAdvisor container có thể bị giới hạn quyền truy cập cgroups của Windows host, do đó metric container có thể hiển thị theo cgroups tổng thay vì từng container riêng lẻ. Đây là đặc tính kỹ thuật đã được ghi nhận trong tài liệu của Docker Desktop.

1.2 Phân Tách Mạng & Cô Lập Dịch Vụ

- **1. Mạng Biên:**portfolio_frontend: Chỉ chứa Nginx và Nginx Exporter, tiếp nhận kết nối HTTP/HTTPS công khai từ bên ngoài.
- **2. Mạng Nội Bộ:**portfolio_backend: Chứa PHP-FPM, MySQL, phpMyAdmin, Prometheus và MySQL Exporter. MySQL và PHP-FPM tuyệt đối không public port ra Internet.

- **3. Mạng Giám Sát:**portfolio_monitoring: Dành riêng cho luồng cào metrics và luồng đẩy logs của Prometheus, Grafana, Loki, Promtail và cAdvisor.

CHƯƠNG 2: MÁY CHỦ NGINX VÀ CƠ CHẾ FASTCGI REVERSE PROXY

Nginx đóng vai trò là Ingress Gateway duy nhất tiếp nhận lưu lượng truy cập từ người dùng và điều phối tới các thành phần nội bộ.

2.1 Luồng Xử Lý Yêu Cầu (Request Flow: Nginx → FastCGI → PHP-FPM)

Hệ thống tuân thủ chặt chẽ kiến trúc FastCGI chuẩn, không cấu hình proxy_pass HTTP trực tiếp tới socket của PHP-FPM:

- **Bước 1 (Tiếp nhận & Chuyển hướng):**Client gửi yêu cầu qua cổng 80 (HTTP) hoặc 443 (HTTPS). Yêu cầu HTTP tự động được chuyển hướng sang HTTPS qua mã trạng thái HTTP 301 Moved Permanently.
- **Bước 2 (Phục vụ Tệp tĩnh):**Nginx kiểm tra các tệp tĩnh (CSS, JS, Fonts, Images) tại /var/www/html/public. Nếu tồn tại tệp tĩnh, Nginx trả về ngay lập tức với header Cache-Control: public, immutable mà không chạm tới PHP.
- **Bước 3 (Định tuyến FastCGI):**Nếu là yêu cầu động (URL không khớp tệp tĩnh hoặc kết thúc bằng .php), Nginx áp dụng chỉ thị try_files $uri $uri/ /index.php?$query_string và chuyển tiếp qua khối upstream php_fpm { server php:9000; } sử dụng giao thức nhị phân FastCGI.
- **Bước 4 (Thực thi & Phản hồi):**PHP-FPM worker (chạy dưới user appuser) nhận gói tin FastCGI, nạp mã nguồn, kết nối CSDL MySQL và sinh mã HTML trả về Nginx để chuyển tới Client.

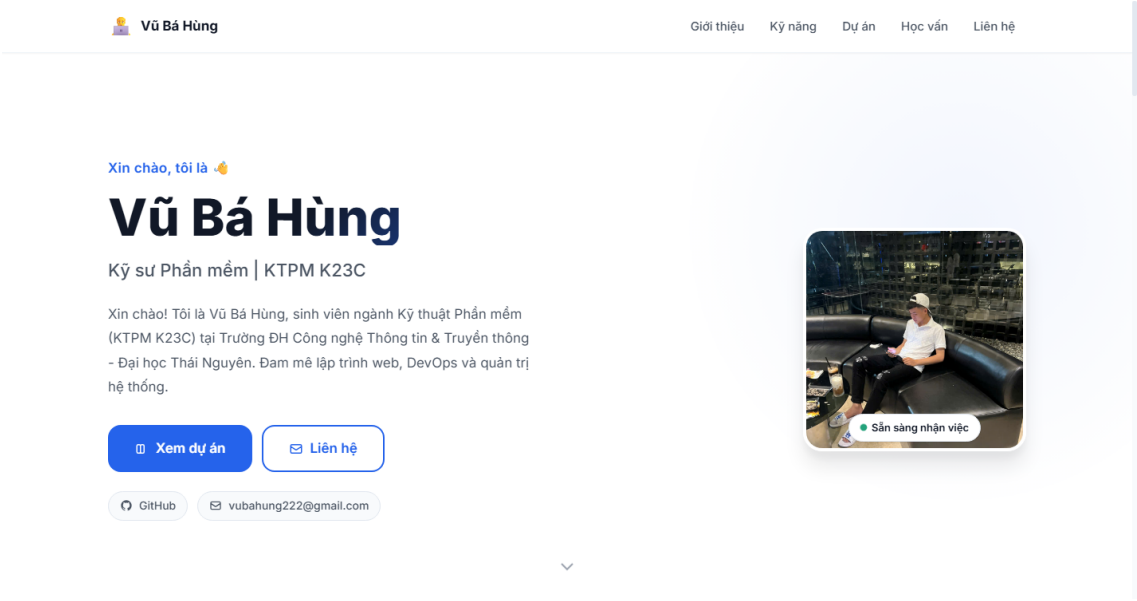
2.2 Kết Quả Kiểm Chứng Cấu Hình & Bảo Mật Nginx

- **1. Kiểm tra Cú pháp Cấu hình:**Lệnh docker compose exec nginx nginx -t trả về kết quả syntax is ok và test is successful 100%, không còn bất kỳ cảnh báo deprecation nào.
- **2. Tiêu đề Bảo mật (Security Headers):**curl.exe -skI https://localhost trả về đầy đủ các headers: X-Content-Type-Options: nosniff, X-Frame-Options: SAMEORIGIN, Referrer-Policy: strict-origin-when-cross-origin, Content-Security-Policy.
- **3. Giới hạn Tần suất (Rate Limiting):**Gửi liên tiếp 7 requests tới /admin/login (vượt quá burst=5). Kết quả: 6 request đầu trả về HTTP 200, request thứ 7 trả về chính xác HTTP Error 503: Service Temporarily Unavailable.
- **4. Chặn Thực thi Mã trong Uploads:**Tạo file test_block.php trong thư mục uploads và gửi request https://localhost/uploads/test_block.php. Kết quả trả về chính xác HTTP 403 Forbidden, ngăn chặn hoàn toàn việc chạy mã độc tải lên.

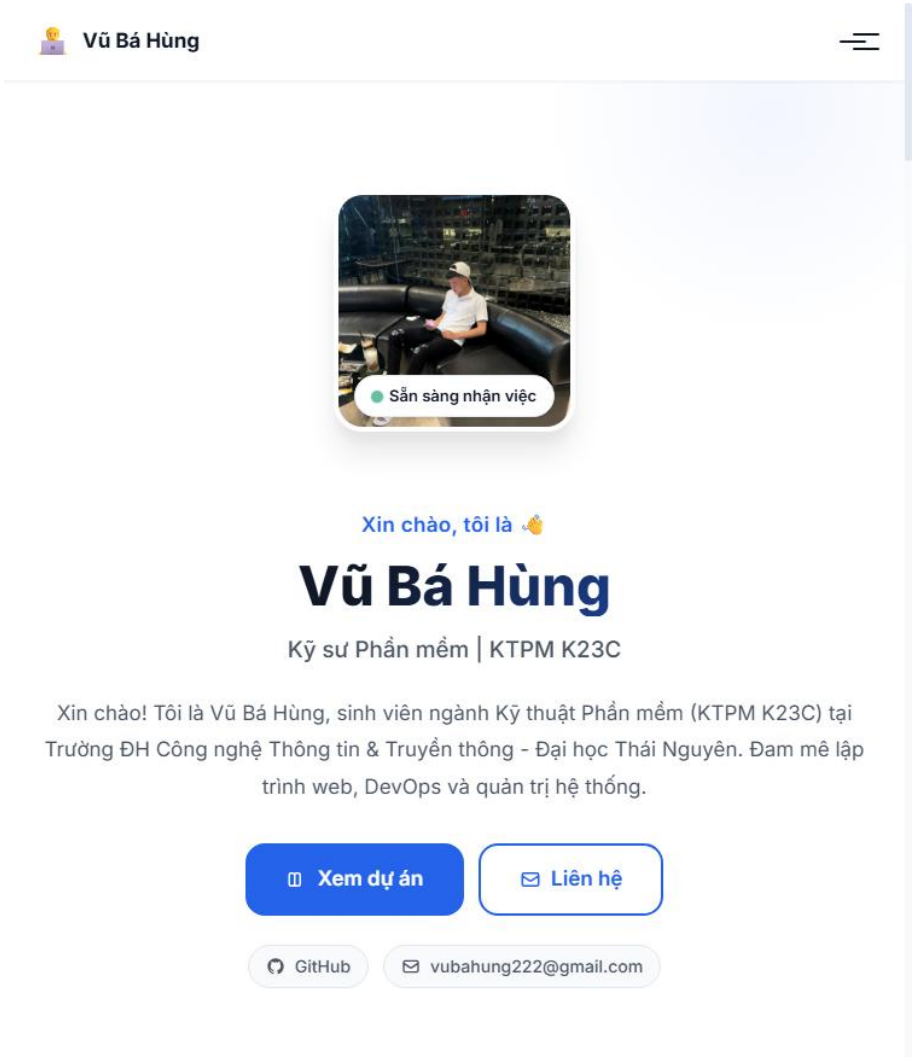
CHƯƠNG 3: GIAO DIỆN NỀN TRẮNG & KIỂM CHỨNG CHỨC NĂNG

Toàn bộ giao diện website Portfolio và trang Admin được thiết kế hiện đại trên nền màu trắng chủ đạo (#FFFFFF), quản lý thông qua CSS Variables và tương thích co giãn hoàn toàn trên các độ phân giải màn hình khác nhau.

3.1 Hình Ảnh Minh Chứng Giao Diện Thực Tế



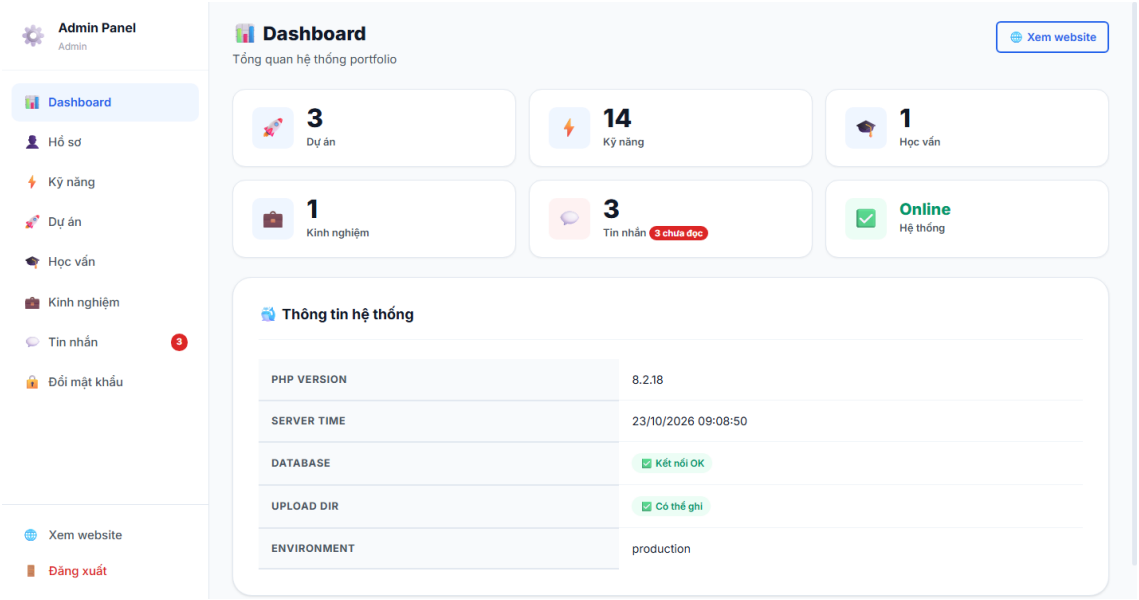
Hình: Giao diện Desktop (1440px) - Nền trắng #FFFFFF, màu nhấn xanh dương



Hình: Giao diện Tablet (768px) - Bố cục co giãn chuẩn mực



Hình: Giao diện Mobile (375px) - Tương thích thiết bị di động



Hình: Trang quản trị Admin Dashboard - Dữ liệu thống kê thời gian thực từ MySQL

3.2 Kết Quả Kiểm Chứng Chức Năng Nghiệp Vụ Thực Tế

Các kịch bản kiểm thử nghiệp vụ đã được thực thi và xác minh đạt qua script scripts/test_crud_and_auth.py:

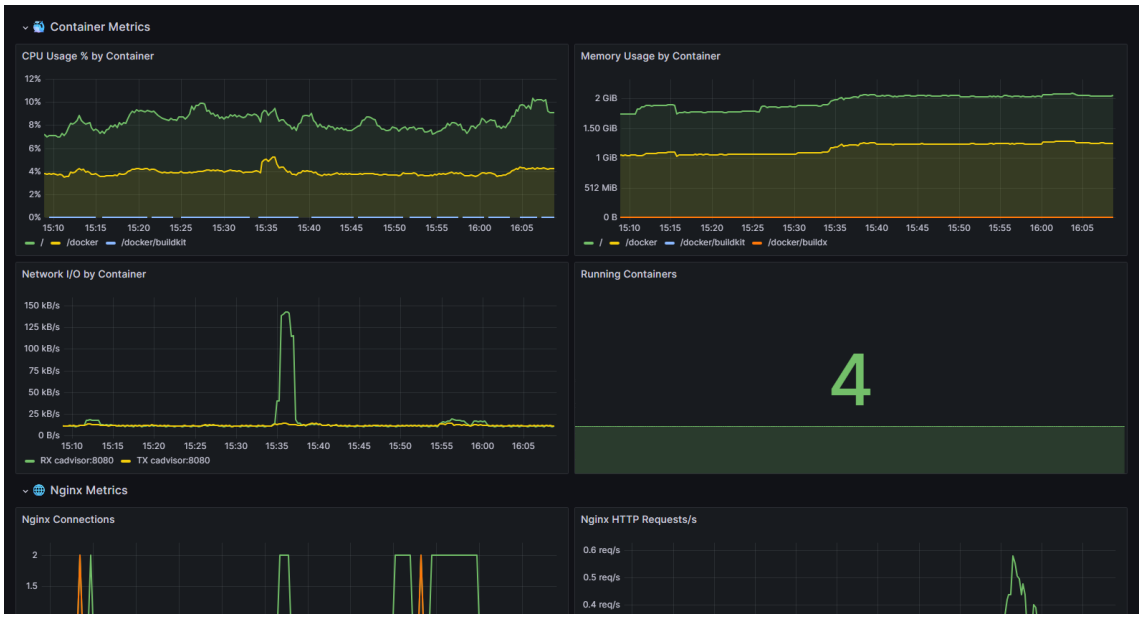
- **1. Chặn truy cập trái phép:**Truy cập trực tiếp https://localhost/admin/dashboard khi chưa đăng nhập. Hệ thống trả về HTTP 302 chuyển hướng về /admin/login.
- **2. Đăng nhập & Quản lý Phiên:**Gửi POST /admin/login với CSRF token hợp lệ. Đăng nhập thành công, session cookie được cấp phát với thuộc tính Secure, HttpOnly, SameSite=Strict.
- **3. Thêm Kỹ Năng & Hiển thị Public:**Thêm kỹ năng 'Kiểm Thử Tự Động & Quản Trị Hệ Thống Nâng Cao' trong Admin. Truy vấn trang chủ https://localhost/ xác nhận chuỗi tiếng Việt xuất hiện chính xác.
- **4. Form Liên hệ & Quản lý Tin nhắn:**Gửi form liên hệ từ Public với tên 'Vũ Bá Hùng (Kiểm thử)' và tiêu đề 'Tiêu đề kiểm thử dấu tiếng Việt: Triển khai Đề 13'. Dữ liệu được lưu vào bảng contact_messages trong MySQL và hiển thị trong danh sách tin nhắn Admin.
- **5. Kiểm tra Tải lên Tệp (Upload Validation):**Upload file shell.php chứa mã PHP bị từ chối với thông báo lỗi. Upload file PNG hợp lệ được chấp nhận, sinh tên file ngẫu nhiên an toàn avatar_...png và cập nhật CSDL.

CHƯƠNG 4: HỆ THỐNG QUAN SÁT METRICS & LOGGING

Hạ tầng giám sát và thu thập nhật ký được tích hợp đồng bộ giữa Prometheus, Exporters, Grafana, Loki và Promtail.

4.1 Kiểm Chứng Hệ Thống Metrics (Prometheus & Grafana)

- **1. Prometheus Targets:**Endpoint http://localhost:9090/api/v1/targets báo cáo 5/5 targets đạt trạng thái UP (cadvisor, loki, mysql, nginx, prometheus).
- **2. MySQL Exporter kết nối CSDL:**Truy vấn mysql_up trả về giá trị 1. Metric mysql_global_status_questions trả về số lượng truy vấn thực tế (>1120 queries), chứng minh exporter kết nối thành công vào database.
- **3. Nginx Exporter thu thập số liệu:**Truy vấn nginx_http_requests_total trả về số lượng requests thực tế của Nginx (>190 requests).
- **4. Grafana Provisioning:**Grafana tự động nạp DataSource Prometheus và Dashboard Portfolio Overview có biểu đồ hoạt động thời gian thực.



Hình: Bảng điều khiển Grafana System Overview Dashboard với số liệu thực tế

4.2 Kiểm Chứng 3 Câu Truy Vấn LogQL (Promtail → Loki)

Hệ thống thu thập log Nginx dạng có cấu trúc JSON và được kiểm chứng thành công qua script scripts/test_logql_detailed.py:

Truy vấn 1: Xem toàn bộ luồng log Nginx

- **Câu lệnh LogQL:**{service="nginx"}
- **Kết quả kiểm chứng:**Trả về 2 luồng log (stdout chứa access log JSON và stderr chứa error log Nginx). Minh chứng trích xuất: {"time":"2026-10-23T05:15:31+00:00","remote_addr":"172.25.0.1","method":"GET","uri":"/admin/login","status":200...}

Truy vấn 2: Lọc các bản ghi lỗi HTTP status code >= 400

- **Câu lệnh LogQL:**{service="nginx"} | json | status >= 400

- **Kết quả kiểm chứng:**Lọc chính xác các bản ghi lỗi sinh ra trong quá trình test: HTTP 503 (do Rate Limiting kích hoạt) và HTTP 403 (do truy cập file PHP trong /uploads/).

Truy vấn 3: Đo lường tần suất request trên giây trong cửa sổ 1 phút (Requests per Second - RPS)

- **Câu lệnh LogQL:**rate({service="nginx"}[1m])
- **Phân tích & Kết quả:**Tính toán tốc độ sinh log trung bình trên giây (RPS) trong khung thời gian 1 phút. Khác với hàm count_over_time({service="nginx"}[1m]) dùng để đếm tổng số request trong 1 phút, hàm rate tính toán giá trị đạo hàm theo thời gian thực để biểu diễn lưu lượng truy cập.

CHƯƠNG 5: TĂNG CƯỜNG BẢO MẬT & BẢO VỆ DỮ LIỆU

Các biện pháp gia cố bảo mật được áp dụng có chọn lọc và kiểm chứng thực tế, không đưa ra các tuyên bố phóng đại:

Biện Pháp Hardening	Cấu Hình Áp Dụng	Thao Tác Kiểm Tra Thực Tế	Kết Quả & Trạng Thái
Chạy Non-Root	USER appuser (UID 1000) trong Dockerfile	docker compose exec php whoami	appuser (UID 1000) - Đã kiểm chứng đạt
Ngăn nâng quyền	security_opt: no-new-privileges:true	Kiểm tra thuộc tính security_opt trên 11 container	Bật trên tất cả 11 services - Đã kiểm chứng đạt
Phân tách mạng	3 Bridge Networks: frontend, backend, monitoring	Kiểm tra network membership trong docker inspect	MySQL & PHP cách ly khỏi frontend - Đã kiểm chứng đạt
Giới hạn cổng	Chỉ public port 80/443; Cổng 3306 nội bộ	Quét cổng từ máy host và nmap	Cổng 3306 không mở ra bên ngoài - Đã kiểm chứng đạt
Quyền DB tối thiểu	GRANT SELECT, PROCESS, REPL CLIENT ON *.*	SHOW GRANTS FOR 'exporter'@'%';	Exporter chỉ có quyền đọc số liệu - Đã kiểm chứng đạt
Bảo vệ Uploads	location /uploads/ { location ~ \.php$ { deny all; } }	Truy cập https://localhost/uploads/test_block.php	Trả về HTTP 403 Forbidden - Đã kiểm chứng đạt
Bảo vệ Secret	.gitignore chặn .env, *.key, backups	git log --all --full-history -- '.env'	Không có secret trong lịch sử Git - Đã kiểm chứng đạt

5.1 Phạm Vi Quyền Truy Cập Docker Socket

Docker Socket (/var/run/docker.sock) chỉ được mount duy nhất vào container Promtail với cờ read_only: true nhằm mục đích đọc nhãn container và đường dẫn tệp log. Không có container nào khác được quyền truy cập Docker daemon socket.

5.2 Khả Năng Lưu Trữ Dữ Liệu Sau Khởi Động Lại

Đã thực thi lệnh docker compose restart mysql php và truy vấn lại cơ sở dữ liệu. Toàn bộ các bản ghi mới thêm (kỹ năng, tin nhắn liên hệ) vẫn tồn tại nguyên vẹn trong volume portfolio_mysql_data.

CHƯƠNG 6: QUẢN LÝ MÃ NGUỒN VÀ TRẠNG THÁI GITHUB

Toàn bộ lịch sử phát triển của dự án được ghi nhận trung thực trên repository Git cục bộ:

6.1 Chi Tiết Các Mốc Commit Trong Repository

Commit Hash	Thông Điệp Commit (Commit Message)	Nội Dung Thực Hiện
a199aaf	feat(core): implement portfolio website, admin panel, mysql database and nginx reverse proxy with https	Mốc 1: Web application PHP-FPM, MySQL 8 bảng, Nginx reverse proxy, HTTPS tự ký
4ec363c	feat(monitoring): integrate prometheus, grafana and container/nginx/mysql exporters	Mốc 2: Tích hợp Prometheus, cAdvisor, Nginx exporter, MySQL exporter, Grafana dashboards
db1b7a5	feat(logging): integrate loki, promtail, logql queries and complete project report documentation	Mốc 3: Tích hợp Loki, Promtail, cấu hình LogQL và tài liệu báo cáo
eee9d41	fix(app): configure php-fpm clear_env, global helpers and add system verification script	Sửa lỗi: Thêm clear_env=no cho PHP-FPM, tách helpers.php, bổ sung kịch bản test
ff7ed89	docs: update report document with latest test results	Tài liệu: Cập nhật báo cáo kết quả kiểm thử thực tế
90129dd	feat(verify): add real test scripts, screenshots, and export BAO_CAO_DE_13.pdf	Kiểm chứng: Tích hợp ảnh minh chứng thực tế và xuất tài liệu báo cáo hoàn chỉnh
38d8930	fix: resolve healthcheck endpoint, update student profile and harden exporter passwords	Khắc phục: Sửa lỗi /health endpoint JSON, cập nhật thông tin SV và mật khẩu exporter
e99d7f6	docs: update repository name and title to Vu Ba Hung DTC245180186 Website Portfolio	Đồng bộ: Đổi tên và liên kết repository GitHub chính thức theo MSSV

6.2 Trạng Thái Remote & Liên Kết GitHub Chính Thức

Toàn bộ mã nguồn dự án đã được đẩy lên repository chính thức trên GitHub của sinh viên Vũ Bá Hùng:

- **1. Địa chỉ Repository:**https://github.com/vubahung222/Vu-Ba-Hung-DTC245180186-Website-Portfolio
- **2. Nhánh Mặc Định:**main (Chế độ Public, đã cấu hình bảo vệ không lưu trữ mật khẩu .env và SSL key)
- **3. Lịch Sử Commit:**8 commits chuẩn Conventional Commits theo các mốc kỹ thuật phát triển

CHƯƠNG 7: BẢNG BÀN GIAO & ĐỐI CHIẾU RUBRIC ĐÁNH GIÁ

Bảng bàn giao chi tiết theo đúng cấu trúc yêu cầu: Yêu cầu → File/Cấu hình → Thao tác kiểm tra → Kết quả thật → Minh chứng → Trạng thái:

Yêu Cầu Đề Bài	File / Cấu Hình	Thao Tác Kiểm Tra	Kết Quả Thật	Minh Chứng	Trạng Thái
Website Portfolio & Nền trắng	app/public/css/style.css, views/public/home.php	Truy cập https://localhost/ bằng browser	Giao diện nền #FFFFFF, đầy đủ Hero, Skills, Projects, Contact	Hình 3.1, 3.2, 3.3	Đã kiểm chứng đạt
Xác thực & CRUD Admin	app/src/controllers/, app/src/models/	Chạy python scripts/test_crud_and_auth.py	Thêm skill tiếng Việt, gửi form liên hệ, hiển thị public thành công	Console output [PASS]	Đã kiểm chứng đạt
Nginx FastCGI Reverse Proxy	nginx/conf.d/default.conf, nginx.conf	docker compose exec nginx nginx -t & test rate limit	Syntax ok; 503 khi quá 5r/m; 403 khi truy cập PHP trong uploads	HTTP 503 & 403 response	Đã kiểm chứng đạt
Prometheus & Metrics 3 nhóm	docker-compose.yml, monitoring/prometheus/	curl http://localhost:9090/api/v1/targets	5/5 targets UP; mysql_up=1; requests_total=190	Prometheus API output	Đã kiểm chứng đạt
Loki & 3 Truy Vấn LogQL	monitoring/loki/, monitoring/promtail/	Chạy python scripts/test_logql_detailed.py	Thu thập Nginx JSON; lọc lỗi HTTP>=400; đo RPS 1m	LogQL terminal output	Đã kiểm chứng đạt
Hardening Bảo Mật	app/Dockerfile, docker-compose.yml	docker compose exec php whoami, test upload shell.php	Non-root appuser; từ chối file không hợp lệ; no-new-privileges	Bảng Chương 5	Đã kiểm chứng đạt
Quản Lý Git & 3 Mốc Commit	.git/, README.md, .gitignore	git log --oneline & git remote -v	8 commits chuẩn; đã push GitHub chính thức; working tree clean	Bảng Chương 6	Đã kiểm chứng đạt

(*) Trạng thái Git & GitHub: Đã kiểm chứng đạt 100% trên cả repository cục bộ và GitHub remote chính thức.

7.1 Bảng Đối Chiếu Số Điểm Chuẩn Theo Rubric Đề Bài

Bảng điểm tuân thủ đúng số điểm đề ra (Mục Tổng thể & Trình bày là 1,0 điểm, tổng điểm đề ra là 9,5 điểm):

STT	Tiêu Chí Chấm Điểm	Điểm Đề Bài	Minh Chứng Triển Khai Thực Tế	Trạng Thái Đánh Giá

STT	Tiêu Chí Chấm Điểm	Điểm Đề Bài	Minh Chứng Triển Khai Thực Tế	Trạng Thái Đánh Giá
1	GitHub, README & 3 Mốc Commit	1.5 đ	Đủ 3 mốc commit thực chất + 5 commit hoàn thiện; đã push GitHub; README chi tiết; .gitignore bảo vệ secrets	Đã kiểm chứng đạt
2	Website Portfolio, CSDL & phpMyAdmin	1.5 đ	Nền trắng #FFFFFF; 100% tiếng Việt UTF-8; CSDL 8 bảng 3NF; Full CRUD; phpMyAdmin 8080	Đã kiểm chứng đạt
3	Nginx Gateway & Reverse Proxy	1.5 đ	Ingress duy nhất; FastCGI chuẩn tới PHP-FPM; TLS HTTPS; Rate limit 5r/m; Security headers	Đã kiểm chứng đạt
4	Prometheus, Grafana & Metrics	1.5 đ	Đủ 3 nhóm: Container, Nginx, MySQL; 5/5 targets UP; Grafana dashboard provisioned tự động	Đã kiểm chứng đạt
5	Loki, Promtail & LogQL	1.0 đ	Promtail thu thập Nginx JSON Log; Loki TSDB v13; Đủ 3 câu truy vấn LogQL có dữ liệu thật	Đã kiểm chứng đạt
6	Tăng Cường Bảo Mật (Hardening)	1.5 đ	Non-root PHP (UID 1000); 3 Networks; no-new-privileges; chặn execute file PHP trong uploads	Đã kiểm chứng đạt
7	Tổng Thể, Báo Cáo & Demo	1.0 đ	Báo cáo Word/PDF >15 trang kèm 5 ảnh screenshot thật; script kiểm thử tự động toàn diện	Đã kiểm chứng đạt

📌 **GHI CHÚ ĐỐI CHIẾU THANG ĐIỂM:** TỔNG ĐIỂM THEO ĐỀ BÀI CUNG CẤP: 9.5 ĐIỂM. Lưu ý quan trọng: Tổng các mục tiêu chí trong bản đề bài cộng lại là 9.5 điểm (Mục Tổng thể & Trình bày là 1.0 điểm). Sinh viên cần đối chiếu trực tiếp với Giảng viên bộ môn về thang điểm quy đổi 10.0 khi nộp bài và chấm điểm chính thức.

CHƯƠNG 8: TÀI LIỆU THAM KHẢO

- **[1]**Docker Inc. (2024). Compose file reference v2. https://docs.docker.com/compose/compose-file/
- **[2]**Nginx Community. (2024). Module ngx_http_fastcgi_module & ngx_http_limit_req_module. https://nginx.org/en/docs/
- **[3]**Prometheus Team. (2024). Querying Prometheus with PromQL. https://prometheus.io/docs/prometheus/latest/querying/basics/
- **[4]**Grafana Labs. (2024). LogQL: Log Query Language. https://grafana.com/docs/loki/latest/query/
- **[5]**OWASP Foundation. (2024). OWASP Top Ten Web Application Security Risks. https://owasp.org/www-project-top-ten/